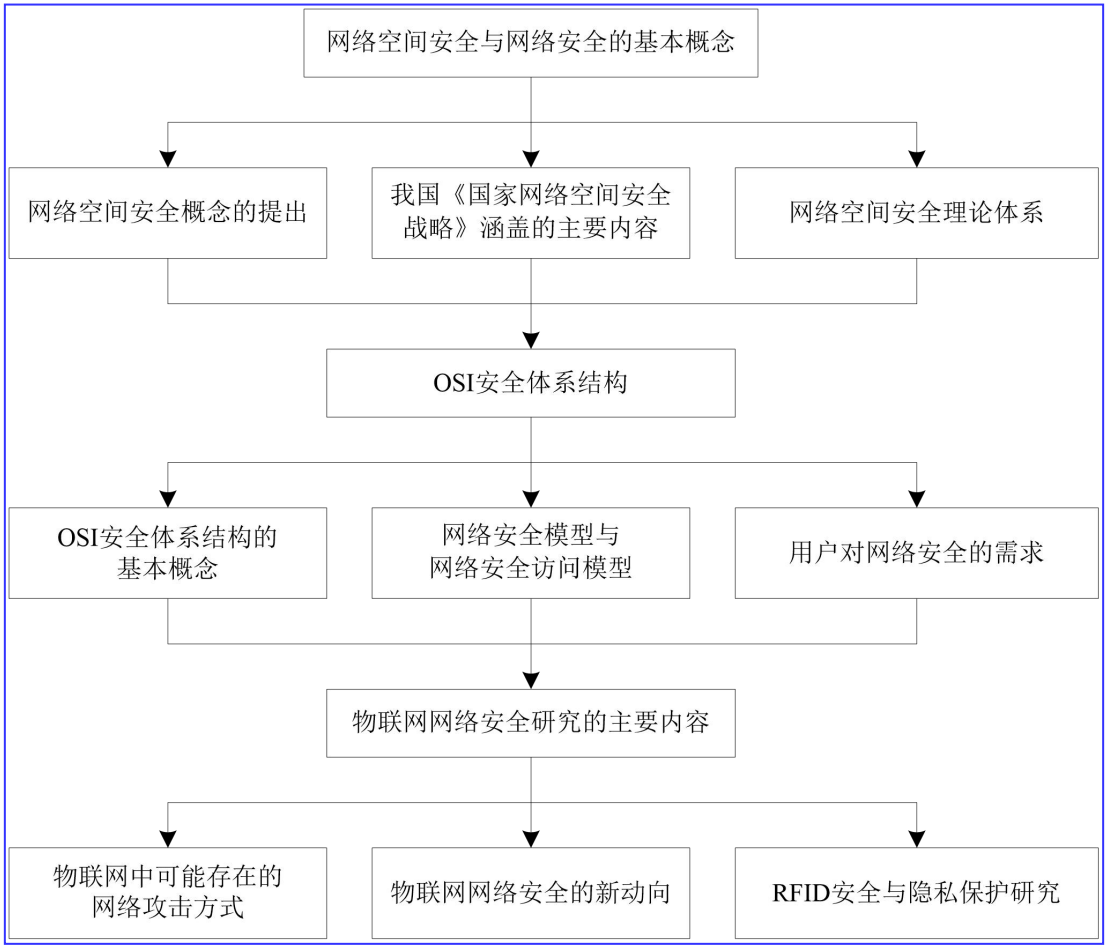


第8章 智能物联网安全技术

本章知识点结构


网络空间安全与网络安全的基本概念
网络空间安全概念的提出
我国《国家网络空间安全战略》涵盖的主要内容
网络空间安全理论体系
OSI安全体系结构
OSI安全体系结构的基本概念
网络安全模型与网络安全访问模型
用户对网络安全的需求
物联网网络安全研究的主要内容
物联网中可能存在的网络攻击方式
物联网网络安全的新动向
RFID安全与隐私保护研究

本章教学要求

- 了解：网络空间安全的基本概念
- 了解：物联网安全的特殊问题
- 了解：物联网安全研究的主要内容
- 了解：物联网的隐私保护问题

8.1 网络空间安全基本概念

8.1.1 网络空间安全概念的提出



《下一场世界战争》作者预言：“在未来的战争中，计算机本身就是武器，前线无处不在，夺取作战空间控制权的不是炮弹和子弹，而是计算机网络里流动的比特和字节。”

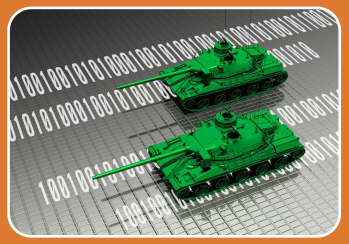


由于互联网、移动互联网、物联网已经应用于现代社会的政治、经济、文化、教育、科研与社会生活的各个领域，那么网络安全必然会成为影响社会稳定、国家安全的重要因素之一



“网络空间（Cyberspace）”被看作是与国家“领土、领海、领空、太空”等四大常规空间同等重要的“第五空间”

8.1.2 我国《国家网络空间安全战略》涵盖的主要内容



我国网络空间安全政策是建立在“没有网络安全就没有国家安全”的理念之上的



2016年12月27日，经中共中央网络安全和信息化领导小组批准，国家互联网信息办公室发布《国家网络空间安全战略》报告



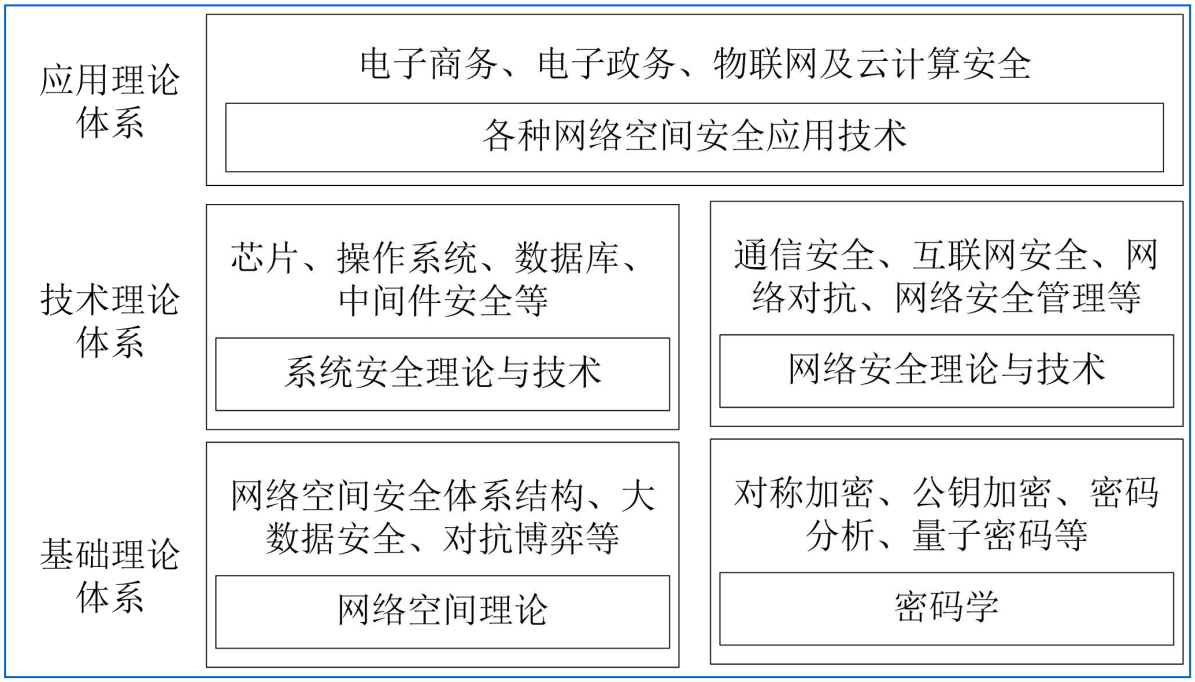
2016年11月7日全国人民代表大会常务委员会通过了《中华人民共和国网络安全法》，并于2017年6月1日起施行

8.1.3 网络空间安全理论体系

<table>
<tr><td colspan="2">应用安全</td><td rowspan="3">密码学
及应用</td></tr>
<tr><td>系统安全</td><td>网络安全</td></tr>
<tr><td colspan="2">网络空间安全基础</td></tr>
</table>

网络空间安全研究包括五个方面的内容：
应用安全、系统安全、网络安全、网络空间安全基础、密码学及其应用

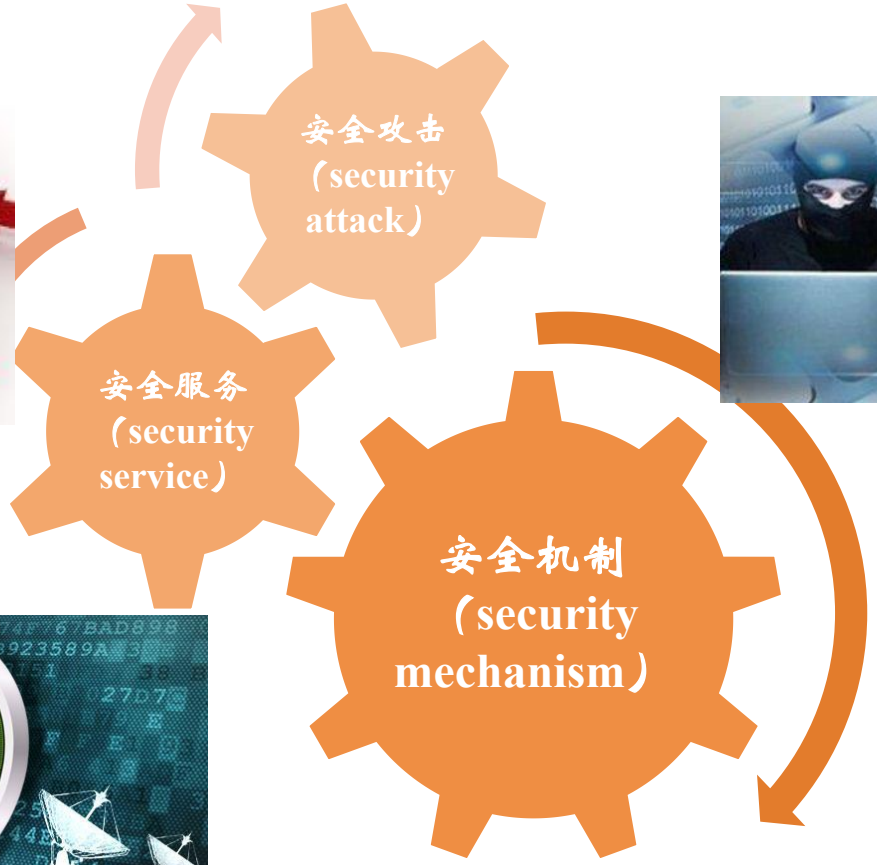
网络空间安全理论体系



网络空间安全理论包括三大体系：基础理论体系、技术理论体系与应用理论体系

8.2 OSI安全体系结构基本概念
8.2.1 OSI安全体系结构的基本内容

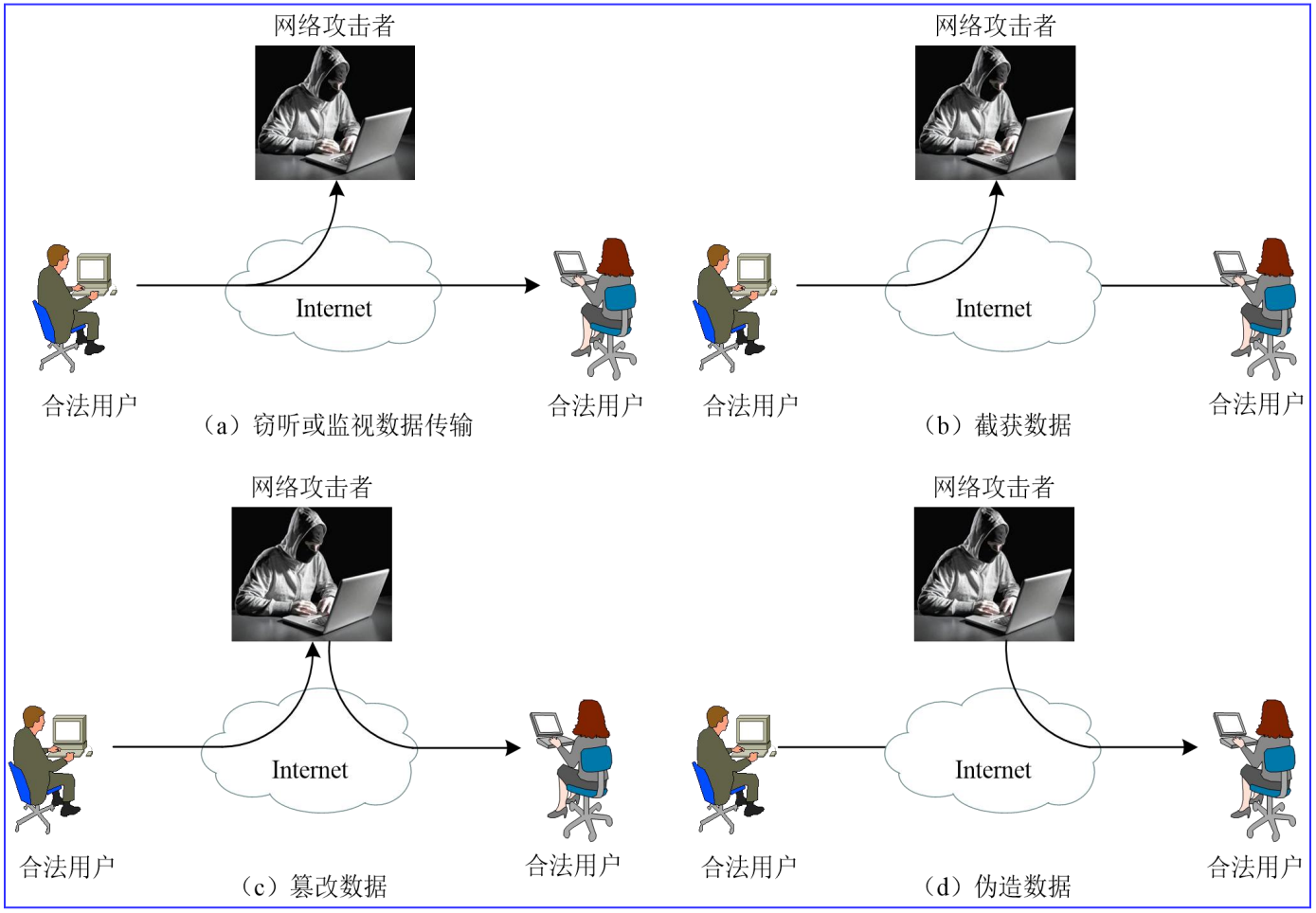








网络攻击的四种类型


网络攻击者
Internet
合法用户
合法用户
（a）窃听或监视数据传输
网络攻击者
Internet
合法用户
合法用户
（b）截获数据
网络攻击者
Internet
合法用户
合法用户
（c）篡改数据
网络攻击者
Internet
合法用户
合法用户
（d）伪造数据

网络攻击类型及特点

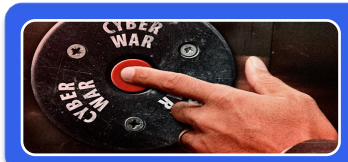
被动攻击（passive attack）

- 窃听或监视数据传输属于被动攻击
- 网络攻击者通过在线窃听的方法，非法获取网络上传输的数据，或通过在线监视网络用户身份、传输数据的频率与长度，破译加密数据，非法获取敏感或机密的信息

主动攻击（active attack）

- 截获数据：网络攻击者假冒和顶替合法的接收用户，在线截获网络上传输的数据
- 篡改或重放数据：网络攻击者假冒接收者，从中截获网络上传输的数据之后，经过篡改再发送给合法的接收用户；或者是在截获到网络上传输的数据之后的某一个时刻，一次或多次重放该数据，造成网络数据传输混乱
- 伪造数据：网络攻击者假冒合法的发送用户，将伪造的数据发送给合法的接收用户

网络安全服务



认证（authentication）：提供对通信实体和数据来源认证与身份鉴别



访问控制（access control）：通过对用户身份认证和用户权限的确认，防治未授权用户非法使用系统资源



数据机密性（data confidentiality）：防止数据在传输过程中被泄漏或被窃听



数据完整性（data integrity）：确保接收的数据与发送数据的一致性，防止数据被修改、插入、删除或重放



防抵赖（non-reputation）：确保数据有特定的用户发出，证明由特定的一方接收，防止发送方在发送数据后否认，或接收方在收到数据后否认现象的发生

网络安全机制

加密（Encryption）— 确保数据安全性的基本方法，根据层次与加密对象的不同，采用不同的加密方法

数字签名（Digital Signature）— 数字签名机制确保数据的真实性，利用数字签名技术对用户身份和消息进行认证

访问控制（Access Control）— 访问控制机制按照事先确定的规则，保证用户对主机系统与应用程序访问的合法性

数据完整性（Data Integrity）— 数据完整性机制确保数据单元或数据流不被复制、插入、更改、重新排序或重放

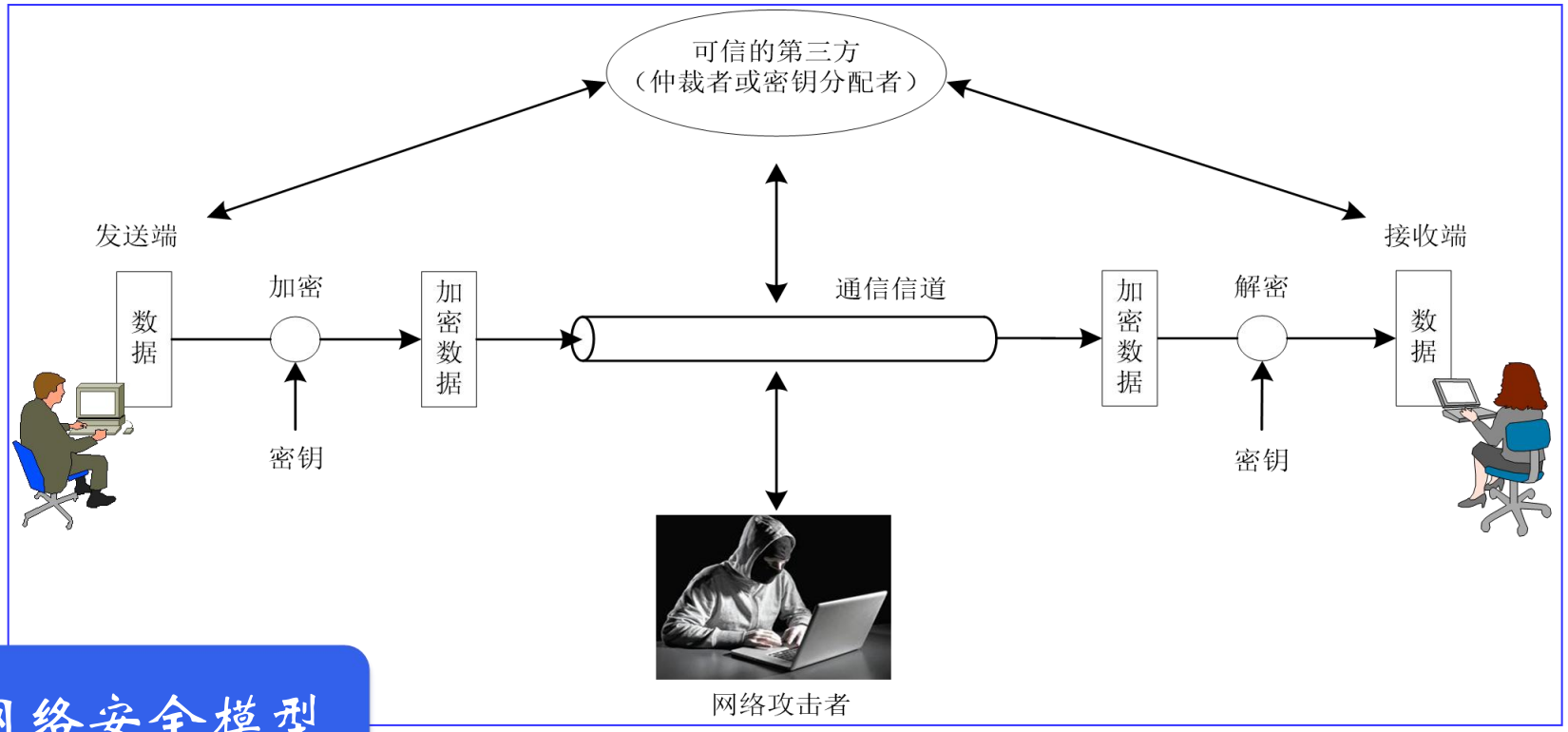
认证（Authentication）— 认证机制用口令、密码、数字签名、生物特征（如指纹）等手段，实现对用户身份、消息、主机与进程的认证

流量填充（Traffic Padding）— 流量填充机制通过在数据流填充冗余字段的方法，预防网络攻击者对网络上传输的流量进行分析

路由控制（Routing Control）— 路由控制机制通过预先安排好路径，尽可能使用安全的子网与链路，保证数据传输安全

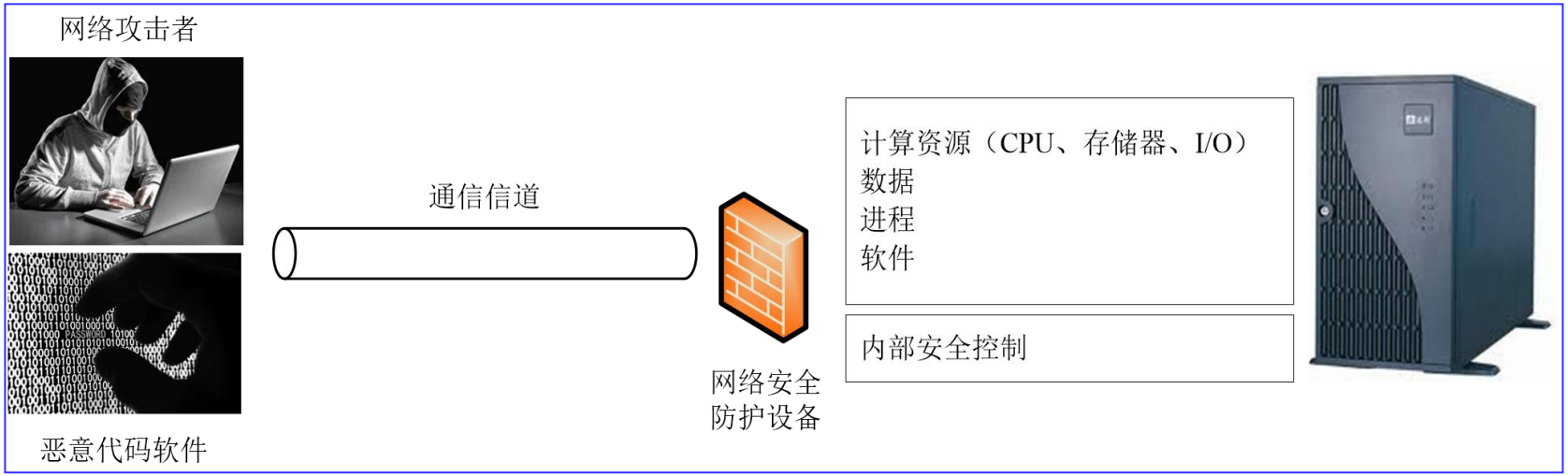
公证（Notarization）— 公证机制通过第三方参与的数字签名机制，对通信实体进行实时或非实时的公证，预防伪造签名与抵赖

8.2.2 网络安全模型与网络安全访问模型



网络安全模型

网络访问安全模型

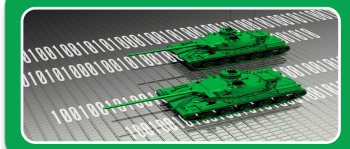


网络安全访问模型主要针对两类对象从网络访问的角度实施对网络的攻击：一类是网络攻击者，另一类是“恶意代码”类的软件

8.2.3 用户对网络安全的需求



可用性：在可能发生的突发事件（如停电、自然灾害、事故或攻击等）情况下，计算机网络仍然可以处于正常运转状态，用户可以使用各种网络服务



机密性：保证网络中的数据不被非法截获或被非授权用户访问，保护敏感数据和涉及个人隐私信息的安全



完整性：保证在网络中传输、存储的完整，数据没有被修改、插入或删除



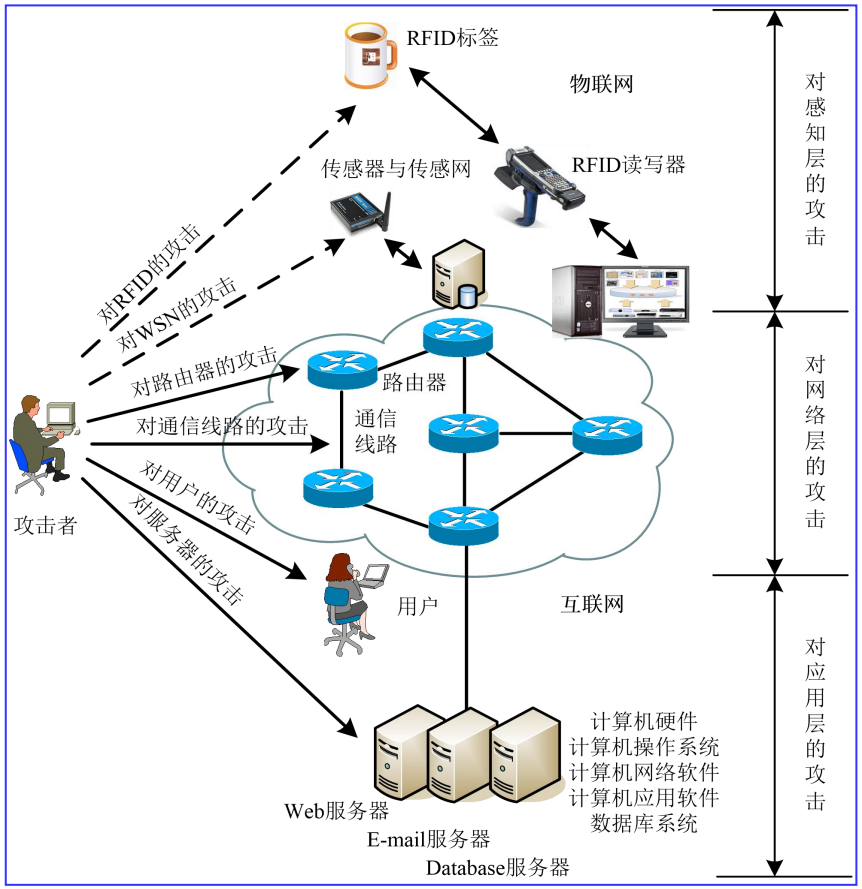
不可否认性：确认通信双方的身份真实性，防止对已发送或已接收的数据否认现象的出现



可控性：能够控制与限定网络用户对主机系统、网络服务与网络信息资源的访问和使用，防止非授权用户读取、写入、删除数据

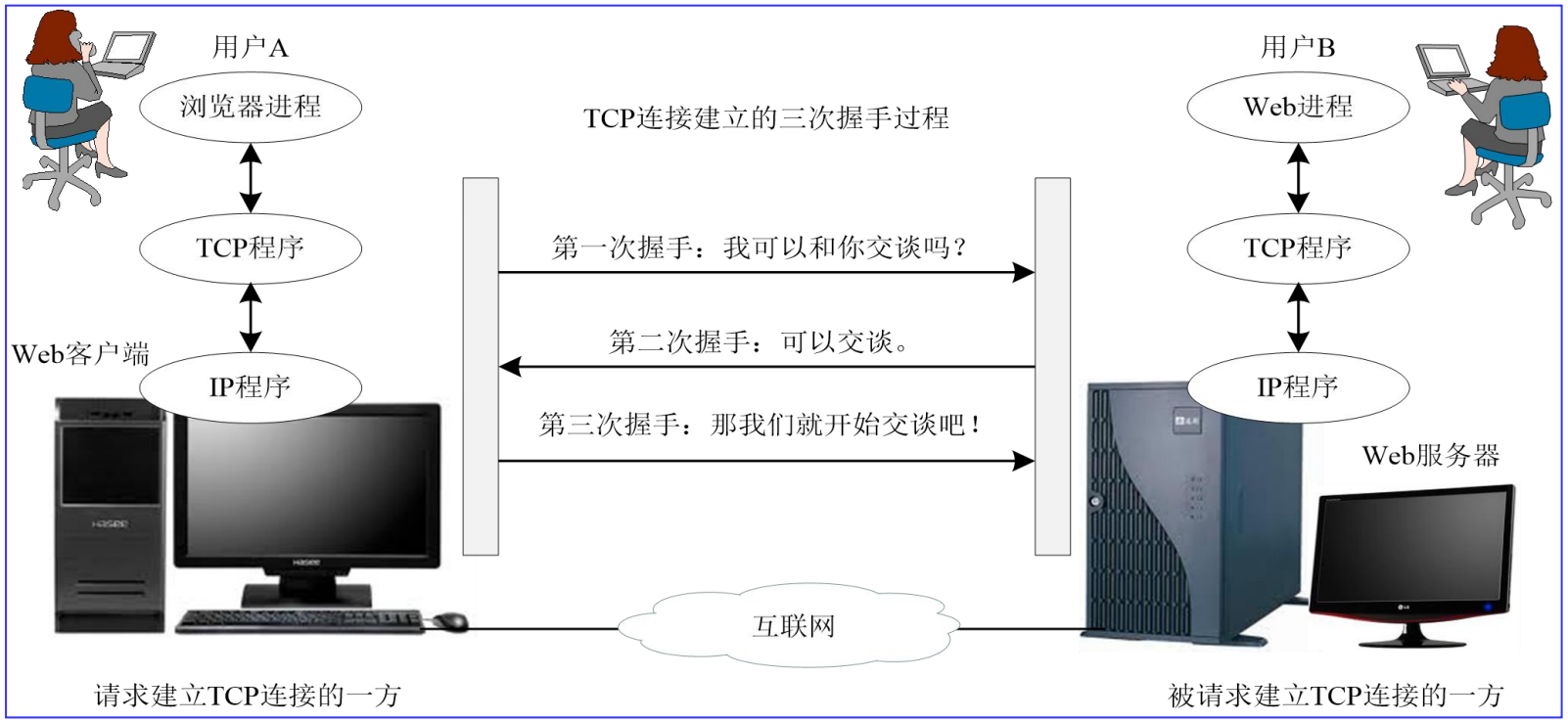
8.3 智能物联网安全研究的基本内容

8.3.1 智能物联网环境的安全问题





典型的网络攻击



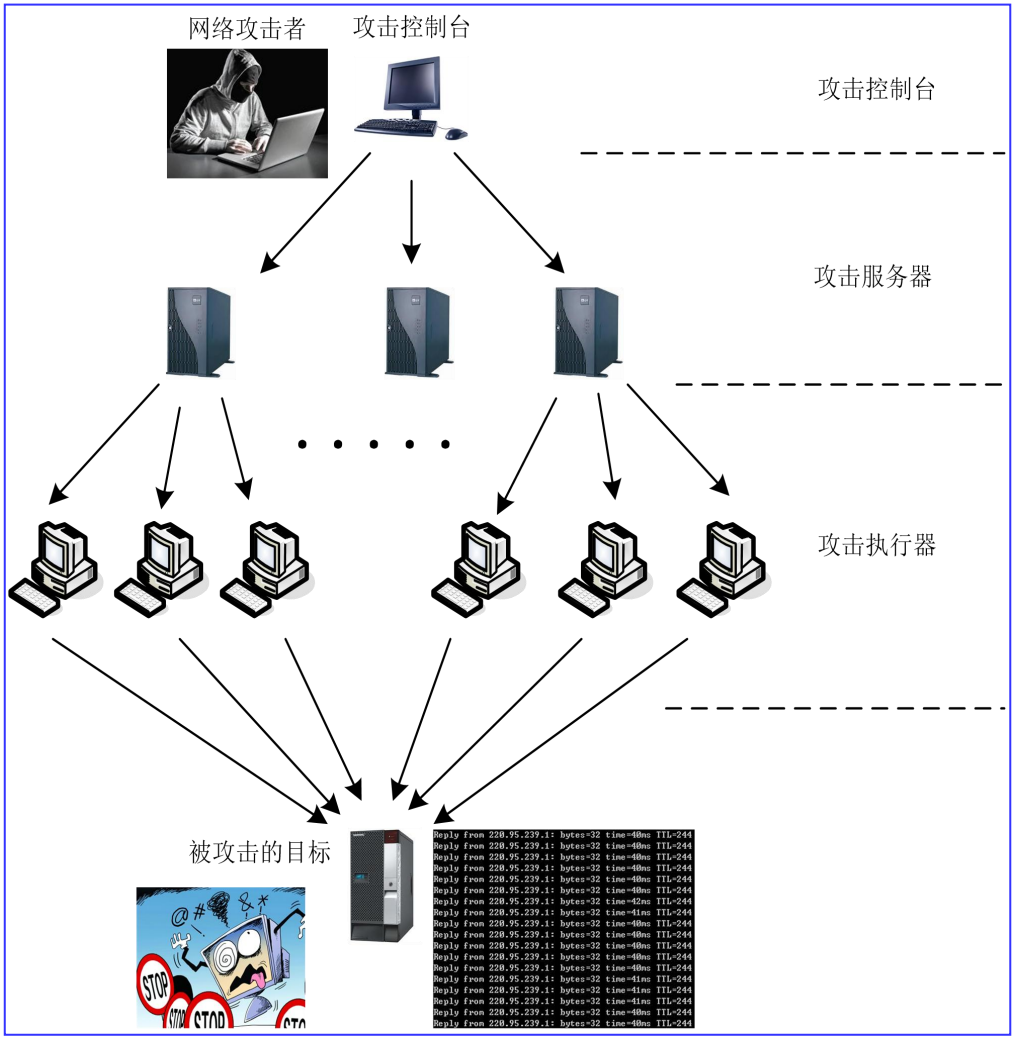
就是这样一个看似成熟和文明的“握手”过程，也可以被网络攻击者利用

DDoS攻击

典型的DoS攻击是资源消耗型DoS攻击：

- 制造大量广播包或传输大量文件，占用网络链路与路由器带宽资源
- 制造大量电子邮件、错误日志信息、垃圾邮件，占用主机中共享的磁盘资源
- 制造大量无用信息或进程通信交互信息，占用CPU和系统内存资源

分布式拒绝服务（DDoS）攻击：在DoS攻击基础上产生的一类攻击形式



8.3.2 智能物联网安全的新动向

➢ 计算机病毒已经成为攻击物联网的工具



火焰（Flame）病毒是一种后门程序和木马病毒程序的结合体，同时又具有蠕虫病毒的特点



火焰病毒被认为是迄今为止发现的最大规模和最为复杂的网络攻击病毒



火焰病毒程序可能是“某个国家专门开发的网络战武器”，病毒将成为攻击物联网的重要工具

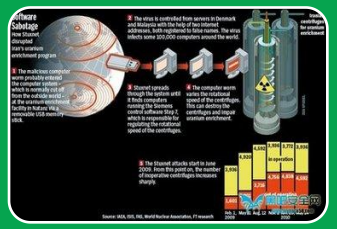
物联网工业控制系统成为新的攻击重点



2010年6月发现的震网病毒是第一个将目标锁定在工业控制网络的病毒



物联网中的智能工业控制系统、智能交通中的无人驾驶车辆、智慧城市中的电梯控制系统、智能电网中的供电控制系统都会成为下一个攻击的重点



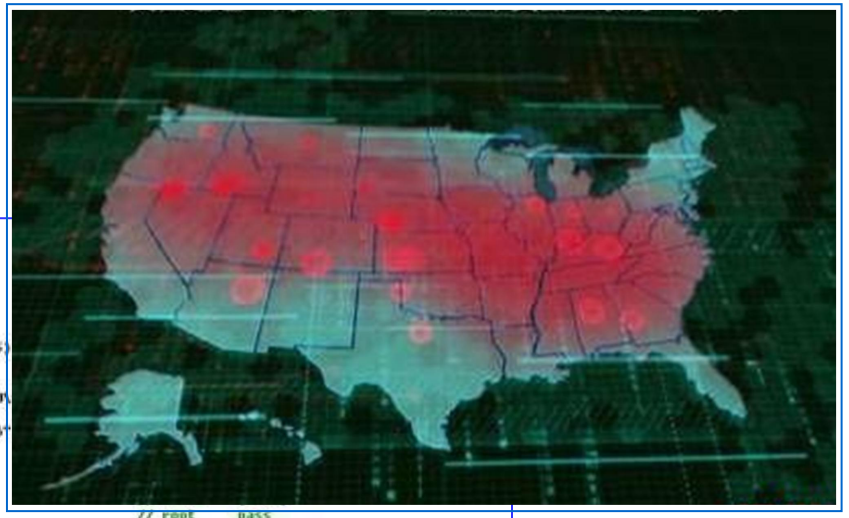
针对物联网的攻击可能造成危及人身安全与社会稳定的重大危害

网络信息搜索功能将演变成攻击物联网的工具



- Shodan搜索引擎主页上写道：“暴露的联网设备：网络摄像机、路由器、发电厂、智能手机、风力发电厂、电冰箱、网络电话”
- 目前已经搜集到的在线网络设备数量超过1000万个，搜索到的信息包括这些设备的准确地理位置、运行的软件等
- 搜索到接入物联网的智能设备与智能系统已经处在危险中

僵尸物联网成为网络攻击新方式



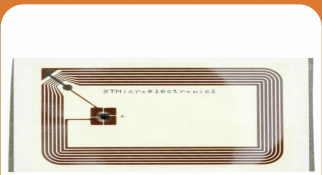
➢2016年10月21日，网络攻击者用木马病毒“Mirai”感染超过10万个物联网终端设备—网络摄像头与硬盘录像（DVR）设备，通过这些看似与网络安全无关的硬件设备，向提供动态DNS服务的DynDNS公司发动DDoS攻击

➢造成美国超过半个互联网瘫痪了6小时，其中Twitter、Airbnb、Reddit等著名的网站，个别网站瘫痪长达24小时

➢这种攻击方式被称为“僵尸物联网（Botnet of Things）”攻击，是第一次出现通过物联网硬件向互联网展开大规模DDoS攻击

➢2017年美国《麻省理工科技评论》将“僵尸物联网”列为十大突破技术之一

8.3.3 智能物联网设备安全



RFID标签的安全缺陷：RFID标签本身的成本所限，RFID很难具备足以自身保证安全的能力



通信信道的安全性问题：RFID使用的是无线通信信道，这就给非法用户的攻击带来了方便



RFID读写器的安全问题：攻击者可以通过仿造读写器，来读写RFID标签数据，或者修改RFID标签中的数据

8.3.3 智能物联网设备安全

- 在物联网应用系统中，感知层由传感器、执行器与用户终端构成。传感器是物联网数据的源头，是整个系统正常运行的基础；执行器的错误动作将导致严重后果，是整个系统运行结果的最终体现
- 物理安全：利用物联网设备的分散部署、无人监管的状态，盗窃、劫持设备或挪动设备位置，影响物联网应用系统的正常运行；插入伪装的物联网设备，提供错误的感知数据，造成物联网应用系统的数据混乱；破坏设备供电或耗尽设备电量，影响物联网应用系统的正常运行；在物联网设备中植入病毒软件，迫使设备参与DDoS攻击

通信安全与数据安全

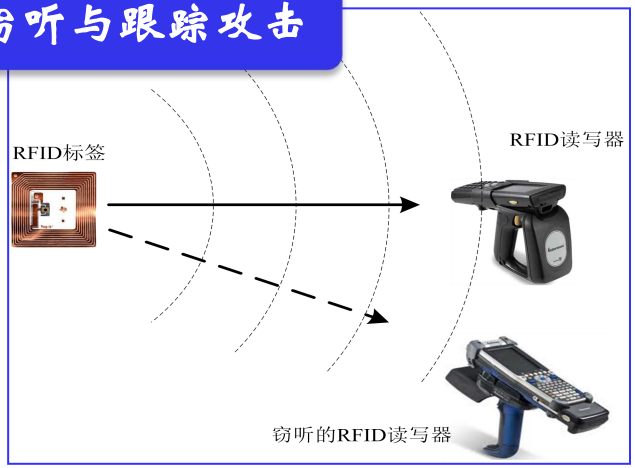
- 通信安全：利用物联网设备在无线信道与通信协议上的漏洞，干扰无线信道或屏蔽无线信号，导致设备之间通信异常甚至难以通信；窃听无线信道或截获无线信号，获得设备之间传输的敏感数据或指令；篡改、重放数据或伪造新的数据，影响物联网应用系统的正常运行
- 数据安全：利用物联网设备在用户使用与管理上的漏洞，直接获取设备默认的用户名与密码，或者对用户设置的弱密码执行字典攻击，获得设备相关的用户账号；利用合法的用户名与密码，窃听、篡改、重放或伪造数据；利用物联网设备的位置信息，将获取的用户数据与位置信息建立关联，分析用户行踪与窥探用户隐私

感知层安全技术

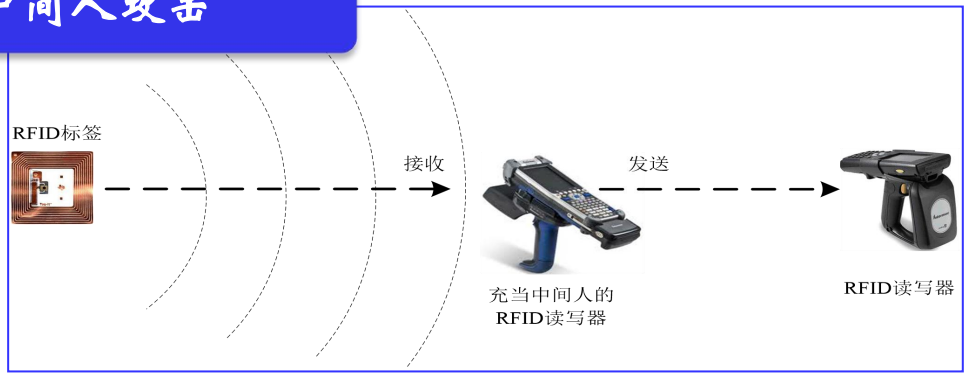
- 轻量级密码算法与认证技术
- 硬件安全组件
- 数据安全
- 隔离技术
- 漏洞挖掘

对RFID系统的攻击

窃听与跟踪攻击



中间人攻击



- 欺骗、重放与克隆攻击
- 破解与篡改攻击
- 干扰与拒绝服务攻击
- 灭活标签攻击
- 病毒攻击



8.3.4 智能物联网接入安全

- 利用无线信道的开放性，窃听、截获、篡改或伪造数据
- 利用通信协议漏洞，采用软件无线电技术攻击物联网
- 发送干扰信号，破坏无线通信的正常工作
- 伪装成合法用户，向系统传输错误数据或指令伪装成基站，发动中间人攻击

接入层安全技术

- NFC安全威胁与防护
- ZigBee安全威胁与防护
- BLE安全威胁与防护
- NB-IoT安全威胁与防护

8.3.5 智能物联网核心交换网安全

- 物联网核心交换网结构比较复杂，可分为两种类型：一种是基于TCP/IP的核心交换网，另一种是基于5G的无线核心网
- 基于TCP/IP的核心交换网可以分成几种类型：一种是安全性要求较高的产业类物联网，核心交换网可能采用自建的IP专网，或者是在公共传输网中组建的VPN网络；也可能有部分物联网的安全性要求较低，或者与外部用户、合作伙伴的数据传输是通过互联网；另一类是消费类物联网，它是借助于互联网的核心交换网实现数据传输

基于TCP/IP的核心交换网安全

- 核心交换网面临的安全威胁来自两方面：一是来自内部的威胁，二是来自外部的威胁。内部威胁主要来自内部用户，这类用户分为两类：一是混入网络管理员队伍的恶意人员，二是不遵守内网使用规范或误操作的用户。恶意人员将会蓄意制造的攻击行为，而不守规范的用户也会引发网络安全事故。外部威胁主要是指各种网络攻击
- 从互联网传承下来的网络安全技术可以归纳为：网络安全体系结构、网络安全防护技术、密码应用技术、网络安全应用技术、系统安全技术等。这些安全技术在长期的互联网应用中不断得到完善，内容比较丰富，技术相对成熟，目前都会用到物联网应用系统中，只是实现方式与保护对象可能有所不同

8.4 智能物联网的隐私保护问题

8.4.1 智能物联网环境中的隐私泄露

- 隐私的内涵很广泛，通常包括个人信息、身体、财产，但是不同的民族、不同的宗教信仰、不同文化的人对隐私都有不同的理解，但是尊重个人隐私已经成为社会的共识与共同的需要
- 除了RFID之外，各种传感器、摄像探头、手机定位功能的不正当使用，都有可能造成个人信息的泄漏、篡改和滥用

8.4.2 隐私保护技术的研究

- 基于身份匿名的隐私保护：身份匿名是用户隐私信息保护的一种重要技术。匿名认证是指用户可以根据应用场景的要求，向服务提供者证明其属于某个特定访问权限的用户集合，但是服务提供者无法识别出用户是集合中的哪个用户。身份匿名可通过密码学技术实现，例如群签名、环签名、零知识证明等
- 基于数据关联的隐私保护：为了处理好隐私保护与数据分析的矛盾，需要对含有隐私信息的数据进行去隐私化处理。去隐私化处理是对数据中可能造成隐私泄露的数据进行适当处理，使数据的公开不容易造成隐私泄露
- 基于位置的隐私保护：位置隐私泄露方式可以分为三种：空间标识泄露、定位跟踪泄露与关联性泄露。相应的位置隐私保护可以分为：基于用户身份标识的位置隐私保护、基于位置信息的位置隐私保护、轨迹隐私保护

谢谢！